

BSc (Hons) Computer Science with Software Engineering

NB5004CEM · Cybersecurity · Level 5 · 20 Credits

Session 11

Observability, Compliance & Resilience



*The operational layer: what must be designed to
happen after deployment*



Block 6 - Operations & Synthesis

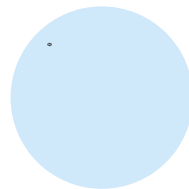
Session 11: Observability, Compliance & Resilience



Session 11 Overview

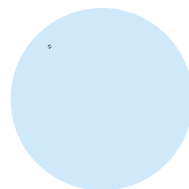
**Accountability, realised operationally:
logging, resilience and compliance as
designed properties**

- Explain why observability is a designed property, not an afterthought (LO2)
- Define RTO and RPO; explain why untested backups are an assumption (LO2)
- Describe ISO 27001, NIST CSF and GDPR at awareness depth (LO2)
- Reconstruct an attack timeline from logs and map each entry to a property (LO3)
- Walk a breach scenario through the IR lifecycle in your assigned domain (LO3)



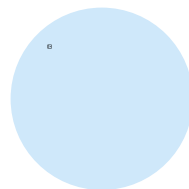
B6 Observability

detection & response



B7 Resilience

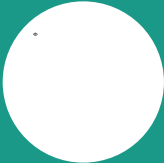
reliability & recovery



B8 Compliance

privacy & audit

Three Components, One Operational Layer



B6
Observability
detection & response



B7
Resilience
reliability & recovery



B8
Compliance
privacy & audit

Part B rubric: Ops & resilience is worth 10% of the coursework mark, drawn entirely from B6, B7 and B8. All three are covered in this single session.

Accountability: from Property to Design



- Accountability was named as one of the five properties in Session 1, and its mechanism (audit trails, non-repudiation) was introduced in Session 5
- Sessions 9 and 10 deepened it: every scan and every config review produced evidence that something happened, or did not
- Session 11 is where Accountability becomes a DESIGNED component: what is logged, how it is aggregated, and how it is protected are architecture decisions, made before deployment
- This session is the operational layer: everything from Session 1 onward now has to keep working, and keep proving it worked, after the system goes live

KEY CONCEPT



Observability is a designed security property, not an ops afterthought.

A system with no audit trail does not lack a feature. It lacks the Accountability property. Logging, correlation and alerting must be specified before deployment, the same way authentication and encryption are.



Logging: the List That Cuts Both Ways

What must be logged

- Authentication events: successful logins, failed attempts, MFA outcomes
- Privilege changes: role assignments, permission grants, account creation and deletion
- Access failures: denied requests to protected resources
- Administrative actions: configuration changes, bulk data exports, system-level commands
- Errors with security implications: repeated exceptions, unexpected access patterns

What attackers try to erase

- Authentication events: successful logins, failed attempts, MFA outcomes
- Privilege changes: role assignments, permission grants, account creation and deletion
- Access failures: denied requests to protected resources
- Administrative actions: configuration changes, bulk data exports, system-level commands
- Errors with security implications: repeated exceptions, unexpected access patterns

It is the same list. An attacker who edits or deletes these entries can make Accountability disappear after the fact.

SIEM: Aggregation, Correlation, Alerting



Analogy

A SIEM (Security Information and Event Management system) is like a building's security control room: dozens of individual camera feeds mean nothing on their own, until someone specifies which combinations of feeds, at which times, should trigger a guard to look twice. The cameras are the logs. The correlation rules are what turn footage into an alert.

SIEM is a Designed Component



- A SIEM performs three jobs: centralised log aggregation, correlation of events across systems, and alerting on defined thresholds
- Its inputs (which systems feed it), its correlation rules (which combinations of events matter), and its alert thresholds (how many failed logins, in what window) must be specified

FAILURE

A SIEM deployed without specification does not fail safe: it produces noise (too many low-value alerts) and misses attacks (the rule that would have caught this one was never written). An unspecified SIEM is a data hoard, not a control.

STRIDE: Repudiation Meets Accountability

- **Repudiation is the STRIDE threat where an actor denies having performed an action, and the system has no evidence to contradict them**
- **Logging is the direct countermeasure: a signed, tamper-evident audit trail is what makes repudiation an unavailable move for an attacker**

COURSEWORK HOOK

Every B6 finding in your report should name the SRS requirement it satisfies (for example, a logging or alerting requirement you defined in Part A) and the layer it sits at, typically Application or System.

Resilience: RTO and RPO



RTO - Recovery Time Objective

- The maximum acceptable time for a system to be offline after a failure
- An Availability requirement: it answers "how long can we be down?"
- Drives infrastructure decisions: failover, redundancy, hot/warm/cold standby

RPO - Recovery Point Objective

- The maximum acceptable data loss, measured in time
- Answers "how old can the most recent backup be?"
- Drives backup frequency: hourly snapshots imply an RPO of about one hour

Backups and Restore Testing



Analogy

A backup you have never restored is like a fire extinguisher you have never checked: it might work when you need it, or the pin might be rusted shut. You do not find out which until the moment you can least afford to.

Backup Strategy: the Design Decisions



- **What is backed up: full system, database only, configuration, or a defined subset**
- **How frequently: continuous, hourly, daily - this sets the RPO directly**
- **Where it is stored: off-site, in a separate account, or in a separate region from the production system, so a single incident cannot take out both**

A Backup Without Tested Restore is an Assumption



A backup strategy that has never been through a restore test is not a control. It is an assumption that the backup works. A backup is only confirmed once a restore has been successfully performed.

COURSEWORK HOOK

Restore testing is a testable SRS requirement: DATA-03. State the acceptance test (a successful restore, performed and observed on a stated schedule), not just the existence of backups.

ISO 27001: Awareness Only



- **An international information security management standard: a framework of controls, not a technical specification**
- **It defines a management system, an ongoing cycle of risk assessment, control selection, and review, not a fixed list of technologies to install**
- **"Certified" means an organisation's information security management system has been independently audited against the standard, not that any specific product or system is inherently secure**

NIST CSF: Five Functions as a Checklist Lens



- **Identify** - know your assets and risks (Sessions 1, 8)
- **Protect** - IAM, application and data controls (Sessions 3-7)
- **Detect** - logging, SIEM, scanning (Sessions 9, 10, 11)
- **Respond** - the IR lifecycle (this session)
- **Recover** - backups, restore testing, RTO/RPO (this session)

Each Part B section maps to one or more of these functions. Use CSF as a lens to check coverage, not as new content to design against.

GDPR Obligations



Core principles

- Data minimisation: collect only what is necessary for the stated purpose
- Purpose limitation: do not repurpose data collected for one reason to serve another
- Privacy by design: privacy and security are a requirement from the start, not a retrofit

Breach notification

- A personal data breach must be reported to the supervisory authority within 72 hours of the organisation becoming aware of it
- This is a hard operational deadline: detection speed (B6) directly determines whether the 72-hour clock leaves enough time to investigate
- Relevant to all six domain industries: banking, healthcare, transport, education, ecommerce, hospitality

Compliance is an External Requirement, Not Bureaucracy



ISO 27001, NIST CSF and GDPR are not administrative add-ons. They are external requirements that the Accountability and Confidentiality properties must satisfy in regulated industries: banking, healthcare, education and ecommerce all answer to a regulator or a standard, whether or not the system design accounts for it.



COURSEWORK HOOK

B8 asks you to name which framework applies to your assigned domain and what it requires of your system, at awareness depth: this is not a law module.

The Incident Response Lifecycle



Introduced here: the model your tabletop exercise will walk through



Detection depends on B6 (was it logged and alerted?). Recovery depends on B7 (RTO, RPO, tested restores). Every stage produces evidence for the GDPR clock and your B9 traceability chain.

Log Analysis I

*Activity - structured log analysis, no tools required,
log file and questions only*

- **Identify the attack type from the evidence in the logs**
- **Reconstruct the timeline**
- **Identify affected accounts**



Log Analysis II

Same log file - two more questions per entry

- **Determine which Accountability controls were present and which were absent**
- **For each log entry: which of the five properties does it help enforce?**



Demo: Log-Timeline Reconstructor - watch the timeline build live

Tabletop IR I

Small Lab - a breach scenario matching your assigned coursework domain

- **Walk through the IR lifecycle: Preparation, Detection, Containment, Eradication, Recovery, Lessons Learned**

Use the six-stage model from the previous slide, in order

Tabletop IR II

At each stage, and for your output

- **At each stage, ask: what evidence exists? What is the GDPR notification obligation? Which resilience control would have prevented or contained the damage?**
- **Output: a brief incident summary noting which properties failed and which B7/B8 controls were absent**

What This Session Makes Writable



- **B6 - Observability, detection and response:** your logging design, SIEM specification and the properties each control enforces
- **B7 - Resilience and reliability:** your RTO/RPO statements, backup strategy and DATA-03 restore-test evidence
- **B8 - Compliance, privacy and audit:** the framework(s) relevant to your assigned domain and what they require of your system

B9 (traceability) is next: Session 12 is where the SRS requirement -> control -> evidence chain you have been building since Session 8 gets assembled into a defensible report, and where the viva rehearses defending it.

Questions & Discussion

*B6, B7 and B8 are writable after today. Session 12
assembles everything into the report.*



Disclaimer & Copyrights



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I do make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability concerning the content within this presentation.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites. I am not responsible for the content of any linked site or any link contained in a linked site.

Any action you take upon the information presented in this presentation is strictly at your own discretion. I will not be liable for any losses or damages in connection with the use of this information.

This disclaimer is subject to change without notice.

@ Images and artworks used in this presentation are used for general informational purposes only. It may contain copyrighted material, the use of which may not have been specifically authorised by the copyright owner. This material is available in an effort to explain issues relevant to the topic. This should constitute a 'fair use' of any such copyrighted material.

Last modified: 10 Jul 2026